

Cookies, Sessão e Status Header

Desenvolvimento Web Back-end

Professor Ivan Luiz Vieira de Araújo

Objetivos da Aula

- Compreender como aplicações Web utilizam cabeçalhos HTTP, códigos de status, a natureza Stateless, cookies e sessões para controlar a comunicação entre navegador e servidor e manter informações durante a interação com o usuário.
- Iremos aprofundar a comunicação HTTP sob três perspectivas:
 - **Status Header** → como o servidor informa o resultado da requisição;
 - **Cookies** → como pequenas informações podem ser armazenadas e reenviadas pelo navegador;
 - **Sessão** → como aplicações conseguem manter um contexto de interação com o usuário.

Onde estamos na disciplina



- O que vimos na aula anterior:

- Evolução da Web;
- Arquitetura Web;
- Cliente e servidor;
- URL;
- DNS;
- Requisição;
- Resposta.



Como Avançaremos?



- Pergunta motivadora:

- Como um site sabe que você já acessou determinada página?

- E também:

- Como o navegador sabe se uma requisição foi bem-sucedida?



O que acontece durante uma comunicação Web?

Relembrando



Lembre-se que informações adicionais são enviadas, aquelas além do conteúdo da página

O que acontece durante uma comunicação Web?

Relembrando.....

1. **Página HTML**

```

```
2. **Requisição: browser solicita imagem**

```
GET /images/tomcat.gif HTTP/1.1
Host: tomat.apache.org
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36
Accept: image/avif,image/webp,image/apng,image/*,*/*;q=0.8
Accept-Language: pt-BR,pt;q=0.9,en-US;q=0.8,en;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```
3. **Resposta: servidor devolve cabeçalho + stream**

```
HTTP/1.1 200 OK
Server: Apache
Date: Sat, 18 May 2024 14:35:21 GMT
Content-Type: image/gif
Content-Length: 23779
Cache-Control: public, max-age=86400
Last-Modified: Wed, 27 Mar 2024 19:14:13 GMT
ETag: "5f87-612d8d41c300"
Accept-Ranges: bytes
Connection: keep-alive

<dados binários da imagem (GIF) ...>
```

Atualizações em relação às versões atuais:

- ✓ Uso de HTTPS (tomcat.apache.org)
- ✓ HTTP/1.1 (ainda amplamente usado)
- ✓ Cabeçalhos modernos (Accept, Accept-Encoding, Cache-Control, ETag, etc.)
- ✓ Compressão suportada (gzip, deflate, br)
- ✓ Conexão persistente (keep-alive)

O que são Headers?



- Headers são informações adicionais utilizadas na comunicação HTTP.
- Podem fornecer informações sobre:
 - conteúdo;
 - comunicação;
 - navegador;
 - servidor;
 - controle de cache;
 - cookies;
 - autenticação.



Request Headers × Response Headers



Request Headers	Response Headers
Cliente -> Servidor	Servidor -> Cliente
Informações da requisição	Informações da resposta
Enviados pelo navegador	Enviados pelo servidor



Por que os Headers são importantes?



- Eles permitem que cliente e servidor troquem informações adicionais sem precisar colocar tudo dentro do conteúdo principal da página.

Headers carregam metadados sobre a comunicação HTTP.



Anatomia de uma resposta

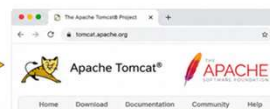


1. Página HTML

```

```

Interpreta
HTML



Gera
requisição
GET

2. Requisição: browser solicita imagem

```
GET /images/tomcat.gif HTTP/1.1
Host: tomcat.apache.org
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/124.0.0.0 Safari/537.36
Accept: image/avif,image/webp,image/apng,image/*,*/*;q=0.8
Accept-Language: pt-BR,pt;q=0.9,en-US;q=0.8,en;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
```

3. Resposta: servidor devolve cabeçalho + stream

```
HTTP/1.1 200 OK
Server: Apache
Date: Sat, 18 May 2024 14:35:21 GMT
Content-Type: image/gif
Content-Length: 23779
Cache-Control: public, max-age=86400
Last-Modified: Wed, 27 Mar 2024 19:14:13 GMT
ETag: "5f87-612d5b4f1c300"
Accept-Ranges: bytes
Connection: keep-alive
<dados binários da imagem (GIF) ...>
```



Atualizações em relação às versões atuais:

- ✓ Uso de HTTPS (tomcat.apache.org)
- ✓ HTTP/1.1 (ainda amplamente usado)
- ✓ Cabeçalhos modernos (Accept, Accept-Encoding, Cache-Control, ETag, etc.)
- ✓ Compressão suportada (gzip, deflate, br)
- ✓ Conexão persistente (keep-alive)

Status Headers



- Os códigos de status HTTP servem para:

O servidor informar ao navegador o que aconteceu com a requisição.



Por que existem códigos de status?



- O cliente precisa saber o que aconteceu com sua solicitação.

- Por exemplo:

- o deu certo;
- o foi redirecionado;
- o o recurso não existe;
- o não possui autorização;
- o ocorreu um erro.



As cinco categorias de status



- 1xx → Informações (Menos utilizados)
- 2xx → Sucesso
- 3xx → Redirecionamento
- 4xx → Erro do cliente
- 5xx → Erro do servidor



**Temos uma vasta
opção de codigos,
a seguir iremos
abordar os mais
usuais**



200 OK	201 Criado	202 Aceito	204 Sem conteúdo	205 Redefinir conteúdo
301 Movido permanentemente	302 Encontrado	303 Ver outro	304 Não modificado	307 Redirecionamento temporário
400 Requisição inválida	401 Não autenticado	403 Proibido	404 Não encontrado	405 Método não permitido
409 Conflito	410 Recurso não está mais disponível	422 Entidade não processável	429 Muitas requisições	451 Indisponível por motivos legais
500 Erro interno do servidor	502 Gateway inválido	503 Serviço indisponível	504 Tempo limite do gateway	511 Autenticação de rede necessária

- 1 Acho que podemos explorar os demais codigos de cada faixa:
Ivan Araújo; 11/08/2026

Principais Códigos de Status HTTP



200 OK: sucesso.

200



Principais Códigos de Status HTTP



302 Found ou **304 Not Modified:** redirecionamento (usados após *login* bem-sucedido).

302

304



Principais Códigos de Status HTTP



401 Unauthorized ou **403 Forbidden**: falha de autenticação/permissão (relacionados a cookies/sessões inválidos).

401

403



Principais Códigos de Status HTTP



404 Not Found: página não encontrada.

404



Principais Códigos de Status HTTP



500 Internal Server Error: erro no código do servidor.

500



Web "Stateless" (Sem Estado)



- O protocolo HTTP, por padrão, não tem memória (é *stateless*).
- Cada requisição é independente.

Pergunta:

Como um *site* de comércio eletrônico, por exemplo, sabe que você adicionou um item ao carrinho se cada interação com o servidor é uma nova requisição?



Cookies



- São pequenos arquivos de texto enviados pelo servidor e guardados no navegador do usuário.

Funcionamento:

- O servidor envia o header Set-Cookie para o navegador.
- O navegador salva e passa a enviar esse cookie de volta em todas as próximas requisições no header Cookie.



Cookies



Atributos	Breve descrição
Expires=<date>	Apresenta a data e hora que o cookie irá expirar
Max-Age=<number>	Número de segundos até os cookies expirarem
Domain=<domain-value>	Define o host ao qual o cookie será enviado
Path=<path-value>	Indica o caminho que deve existir na URL
Secure	O cookie só é enviado em requisições HTTPS - boolean
HttpOnly	Proíbe o acesso ao cookie com a propriedade <code>document.cookie</code>



Os Três Pilares Funcionais do Cookies



Gerenciamento de Sessão

- Autenticação de Logins
- Carrinhos de compras
- Status de progresso (ex: vídeos)



Personalização

- Preferência de idioma
- Temas (Dark/Light mode)
- Configurações de acessibilidade



Rastreamento (Tracking)

- Comportamento analítico
- Frequência de cliques
- Direcionamento de anúncios

Cookies



- Pode ser utilizada para:

- o preferências;
- o identificação;
- o configurações;
- o funcionalidades da aplicação.



Cookie não é Banco de Dados



- É importante diferenciar:
 - Cookie
 - → pequena informação armazenada no navegador.
 - Banco de Dados
 - → armazenamento estruturado de informações da aplicação.

O cookie não substitui um banco de dados.



Cuidados com Cookies



- Cookies podem envolver informações importantes.
- Por isso, existem mecanismos para controlar:
 - duração;
 - domínio;
 - caminho;
 - segurança;
 - envio em determinadas situações.



O problema que a Sessão resolve



- Imagine um sistema acadêmico.
- O usuário faz login.
- Depois acessa:
- Notas -> Frequência -> Disciplinas -> Boletim
- Como o sistema sabe que todas essas solicitações pertencem ao mesmo usuário?



Sessão



- Uma sessão representa um período de interação entre um usuário e uma aplicação.
- Durante essa interação, a aplicação pode manter informações relacionadas àquele usuário.
- Dados armazenados de forma centralizada no servidor.



Sessão



▪ Funcionamento:

- O servidor gera um identificador único (ex: Session ID).
- O servidor envia esse ID para o navegador por meio de um cookie.
- Ao receber dados do cliente (ex.: nome do usuário, carrinho), o servidor os guarda no seu próprio banco ou memória.

Sessão representa o contexto de uma interação entre usuário e aplicação.



Cookies vs. Sessão



Cookie:

- Os dados ficam expostos no cliente.
- Menos seguro para dados sensíveis.

Sessão:

- Os dados ficam protegidos no servidor.
- O cliente só tem a "chave" (o Session ID).



Ciclo de Vida do Estado: Criação



O **Set-Cookie** é uma instrução do servidor ordenando que o computador do cliente grave esta string textualmente em seu armazenamento local.

Cookies vs. Sessão



Cookies	Sessão
Armazenado no cliente	Contexto mantido pela aplicação
Navegador participa do armazenamento	Servidor normalmente mantém os dados
Pode carregar um identificador	Associada a um usuário/interação
Pode persistir por determinado período	Possui ciclo de vida

Ciclo de Vida do Estado: Reconhecimento

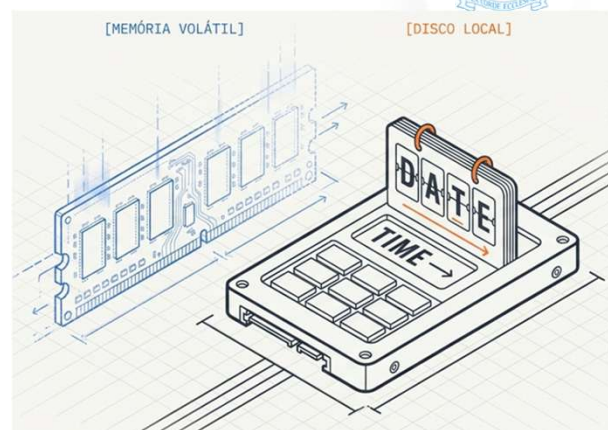


No acesso subsequente, o navegador anexa automaticamente o cabeçalho Cookie. O servidor reconhece o ID único e devolve uma resposta baseada neste estado previamente salvos

Ciclo de vida: O tempo



A primeira grande distinção entre os cookies é baseada na sua volatilidade. Quando o servidor cria a resposta, ele decide se a memória será **efêmera** ou **persistente** através de atributos específicos.



Como Cookie e Sessão trabalham juntos?



- Cookie e Sessão funcionam em conjunto para resolver uma limitação fundamental do protocolo HTTP: a sua natureza stateless (sem estado).
- Como o servidor não reconhece o usuário entre uma requisição e outra, esses dois recursos trabalham como um sistema de comprovante e guarda-volumes.



Como Cookie e Sessão trabalham juntos? O Papel de Cada Um



- Sessão (Lado do Servidor): Armazena os dados sensíveis e o estado real do usuário (ex: carrinho de compras, dados de login, preferências). Fica mantida na memória do servidor, no banco de dados ou em um cache (como Redis).
- Cookie (Lado do Cliente): Armazena apenas uma chave única de identificação (o ID da Sessão ou Session ID). É um arquivo de texto simples mantido pelo navegador do usuário.

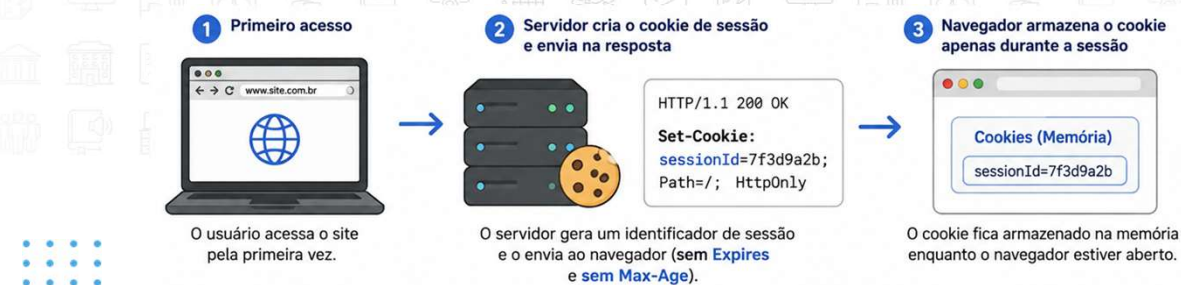


Cookies de Sessão: Início



Conhecidos como **non-persistent** cookies.

- Iniciam no primeiro acesso
- **Não carregam** os atributos **Expires** ou **Max-Age**.



Cookies de Sessão: Encerramento



Expiram instantaneamente quando a conexão é encerrada ou o navegador é fechado



Importante

Cookies de sessão (non-persistent) não possuem os atributos **Expires** ou **Max-Age**.

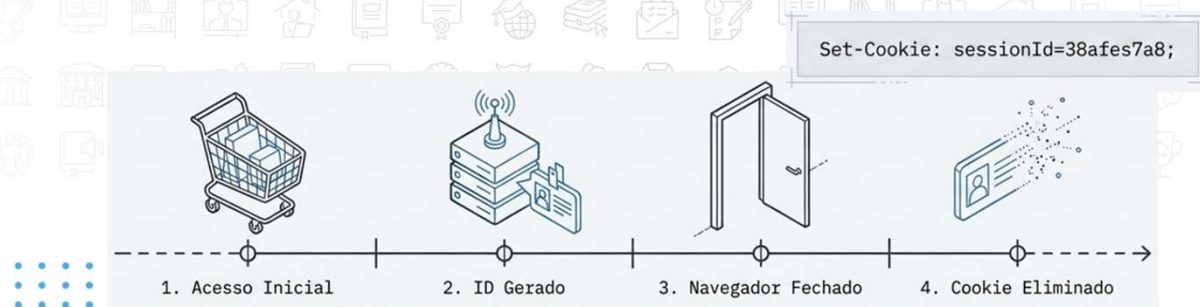
- ✗ Não possuem Expires
- ✗ Não possuem Max-Age

Cookies de Sessão: Exemplo



Exemplo clássico: Carrinho de compras em um e-commerce.

- Guarda os itens enquanto a sessão dura, sumindo após o fechamento.



Cookies Persistentes: Início



Armazenados localmente no dispositivo do usuário.

- Permanecem após fechamento do navegador
- **Carregam** os atributos **Expires** ou **Max-Age**.



Cookies Persistentes: Encerramento



Quando a data/hora de expiração é atingida (Expires) ou o tempo do Max-Age se esgota, o cookie é removido automaticamente. Também pode ser removido manualmente pelo usuário.

Exemplo

Max-Age=2592000
2592000 segundos =
exatos 30 dias



Cookie removido
após expirar ou
ser deletado.

Cookies Persistentes: Exemplo



Manter o usuário autenticado por longo período, mesmo após fechar e reabrir o navegador

1 Primeiro acesso

Usuário faz login no site e marca a opção "Lembrar-me".



O site autentica o usuário.

2 Servidor cria o cookie permanente e envia na resposta



```
HTTP/1.1 200 OK
Set-Cookie:
authToken=eyJhbGc...;
Path=/; HttpOnly; Secure;
Max-Age=1209600;
Expires=Mon, 27 May 2024
10:00:00 GMT
```

O cookie contém um token de sessão e é configurado para durar (ex.: 14 dias = 1.209.600 segundos).

3 Navegador armazena o cookie no disco local



O cookie é salvo no disco do dispositivo do usuário.

4 Próximos acessos

(mesmo após fechar o navegador)



O cookie é enviado automaticamente em cada requisição, mantendo o usuário conectado.

Cookies Persistentes: Vantagens



Algumas vantagens:

- Melhorar experiência do usuário;
- Mantém preferências de sessões por mais tempo;
- Ideal para autenticação persistente e personalização.

Importante:

- Sempre use atributos de segurança como **HttpOnly** e **Secure** para proteger cookies contra ataques.

Ciclo de Vida dos Cookies: Resumo



[MEMÓRIA VOLÁTIL] Cookie de Sessão (Session Cookie)



[DISCO LOCAL] Cookie Persistente (Persistent Cookie)



Cookies + Sessão + HTTP



- O HTTP transporta as requisições e respostas;
- O cookie permite ao navegador transportar um identificador;
- A sessão permite ao servidor manter o estado associado a esse identificador.

Elemento	Papel
HTTP	Transporta requisições e respostas
Cookie	Armazena e transporta informações entre requisições
Session ID	Identifica uma sessão
Sessão	Mantém informações relacionadas à interação do usuário



Conceito-chave

HTTP é **stateless** → Cookie transporta o **identificador** → Sessão mantém o **estado**.

Experiência do Usuário X Privacidade

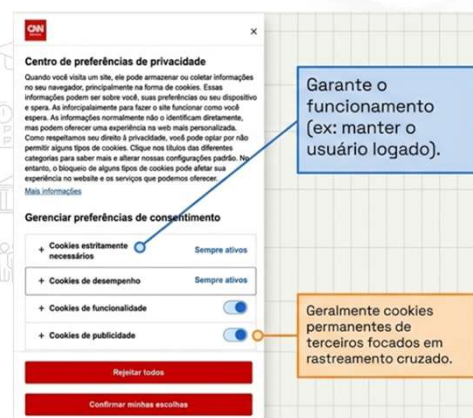


Devo aceitar todos os cookies?

Depende:

- Fazer login repetidamente ou ver um vídeo no Youtube é resolvido pelos cookies.

Porém, LGPD exige clareza sobre o que é essencial e o que é publicidade.



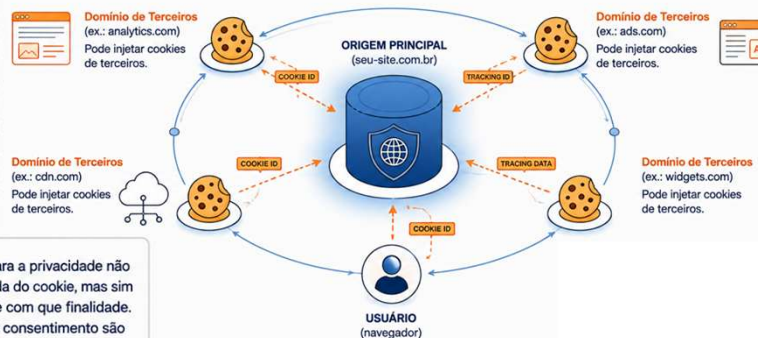
O Escopo de Origem

Ser temporário ou permanente não é o problema central para a privacidade. O maior conflito com a LGPD reside no compartilhamento de informações. A questão fundamental é: quem está injetando o cookie?

A duração do cookie é apenas uma dimensão. Para analisar seu impacto sobre a privacidade, também é necessário considerar sua origem e a finalidade do uso dos dados.

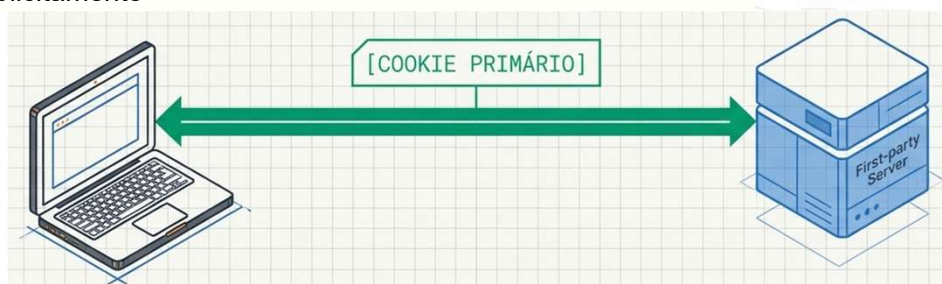


O maior risco para a privacidade não é o tempo de vida do cookie, mas sim quem o define e com que finalidade. Transparência e consentimento são essenciais.



Cookies First-Party (Primários)

Criados e enviados diretamente pelo servidor responsável pelo domínio acessado explicitamente



Função Principal

- Salvar dados legítimos da sessão
 - como itens de carrinho e credenciais de autenticação
- Existem exclusivamente para melhorar a experiência no site anfitrião

Cookies Third-Party (De Terceiros)



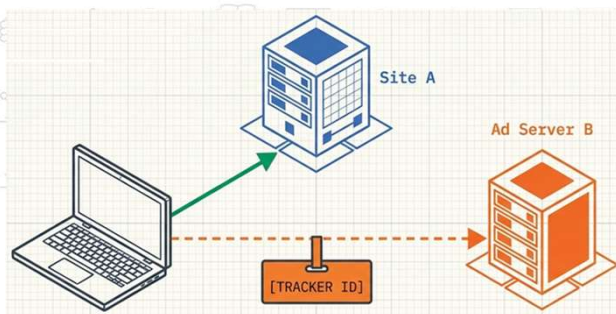
Instalados por um domínio diferente do visitado, exemplo:

- Botões de curtir, chats e banner de anúncios injetados na página anfitriã.

Ameaça Invisível

Não é necessário clicar na propaganda.

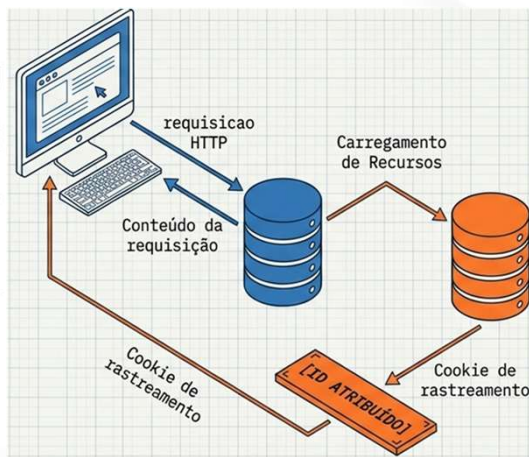
- O simples carregamento permite que o servidor terceiro injete o cookie de rastreamento diretamente no navegador



Rastreamento Externo



1. **Requisição Inicial:** Cliente envia requisição HTTP para o servidor first-party.
2. **Carregamento de Terceiros:** O site carrega recursos (ex: imagens, banners) solicitando dados ao servidor third-party.
3. **Injeção do ID:** O servidor externo recebe a requisição, atribui um ID único ao usuário e envia um cookie de rastreamento na resposta.
4. **Consolidação:** O conteúdo principal é entregue, mas o navegador agora carrega o rastreador externo, monitorando o acesso via um único domínio.

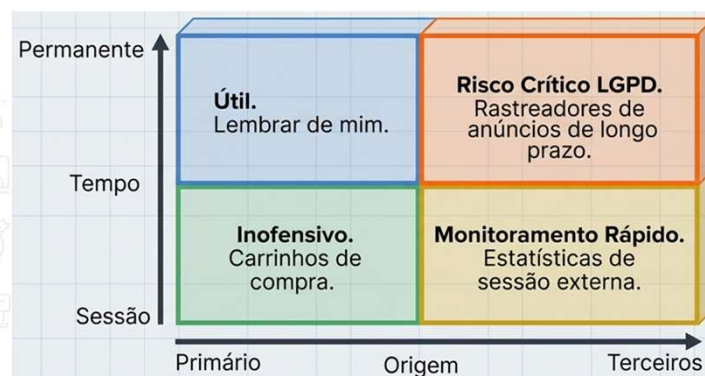


Matriz de Escopo de Compartilhamento



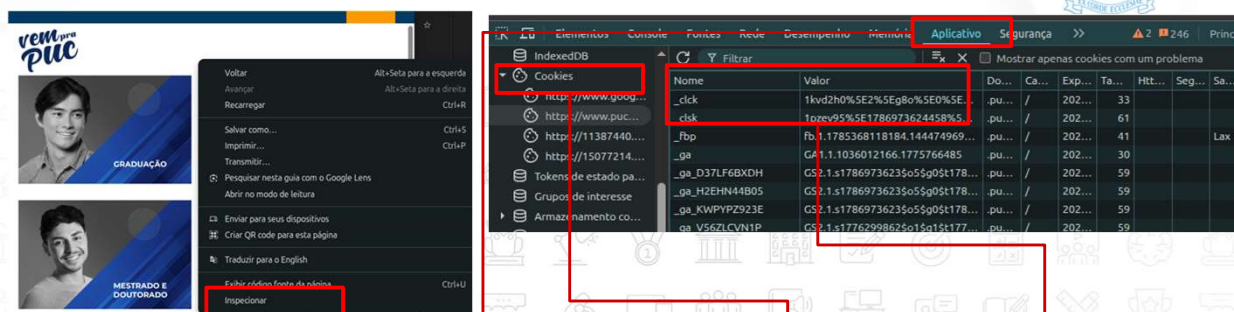
Escopo	Cookie Primário 	Cookie Secundário 	Cookie de Terceiros 
Natureza	Domínio visitado	Mesmo que o primário, mas compartilhado	Domínio externo/diferente
Acordo	Implícito/Direto	Contrato de parceria de dados	Injeção de scripts externos
Uso Comum	Autenticação, Carrinho	Relatórios integrados (ex: Microsoft Teams)	Anúncios, botões Curtir, Tracking

Matriz de Risco dos Cookies



O cruzamento entre persistência no disco e origem externa gera maior atrito com a legislação de dados vigente.

Inspeccionar o Navegador



Passo 01:
Clique com o botão direito na página e selecione **Inspeccionar** (ou F12 / Ctrl+Shift+I).

Passo 02:
No menu superior do **DevTools**, localize a aba **Aplicativo** (Application).

Passo 03:
No menu lateral esquerdo, expanda a árvore de **Armazenamento** e clique em **Cookies**.

Passo 04:
Selecione o domínio para visualizar a tabela de dados (Nome, Valor, Data de Expiração).

Na aula de laboratório iremos abordar de forma prática os conceitos vistos até aqui. Até lá!



PUC Minas

© PUC Minas • Todos os direitos reservados, de acordo com o art. 184 do Código Penal e com a lei 9.610 de 19 de fevereiro de 1998.
Proibidas a reprodução, a distribuição, a difusão, a execução pública, a locação e quaisquer outras
modalidades de utilização sem a devida autorização da Pontifícia Universidade Católica de Minas Gerais.